

University of Minho
School of Engineering



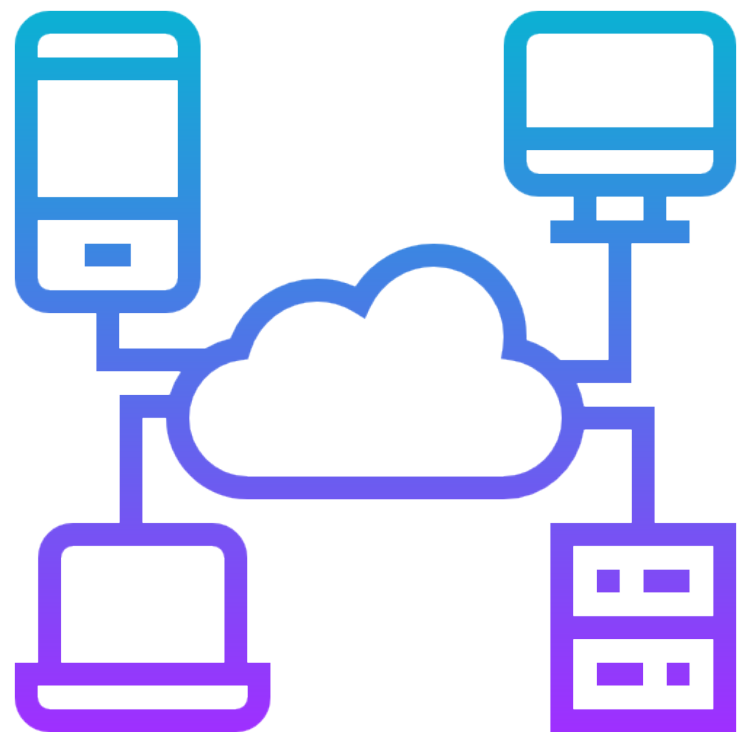
Cryptography & Network Security

Bachelor in Telecommunications and Informatics Engineering

João Marco Silva

Department of Informatics
joaomarco@di.uminho.pt

2024/2025



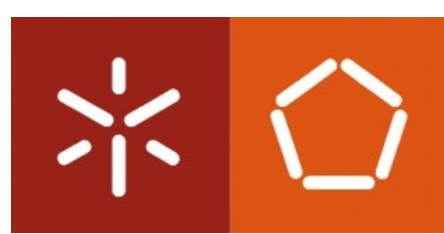
Network Security

Common tools



Network Security

Cyberattacks



Motivation

Political
Personal
Criminal
Commercial
Financial gain
Corporate espionage
Reputational damage
Destruction
Extortion
Vandalism

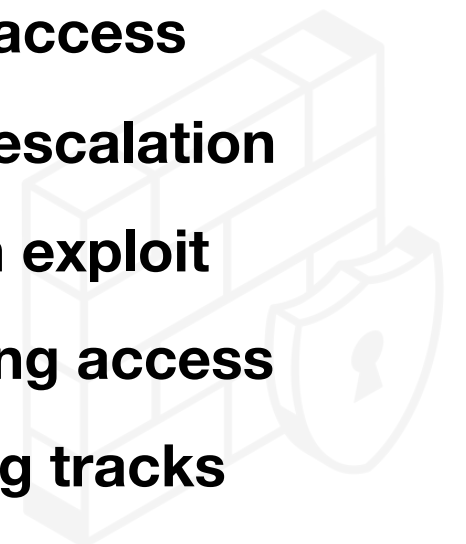


Skill level

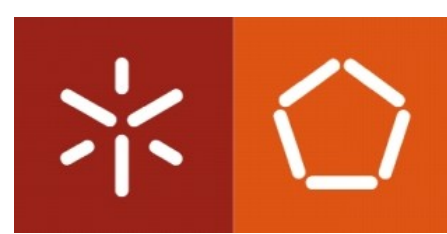
Apprentice
Journeyman
Expert
Specialist

Behavior

Information gathering
Initial access
Privilege escalation
System exploit
Maintaining access
Covering tracks



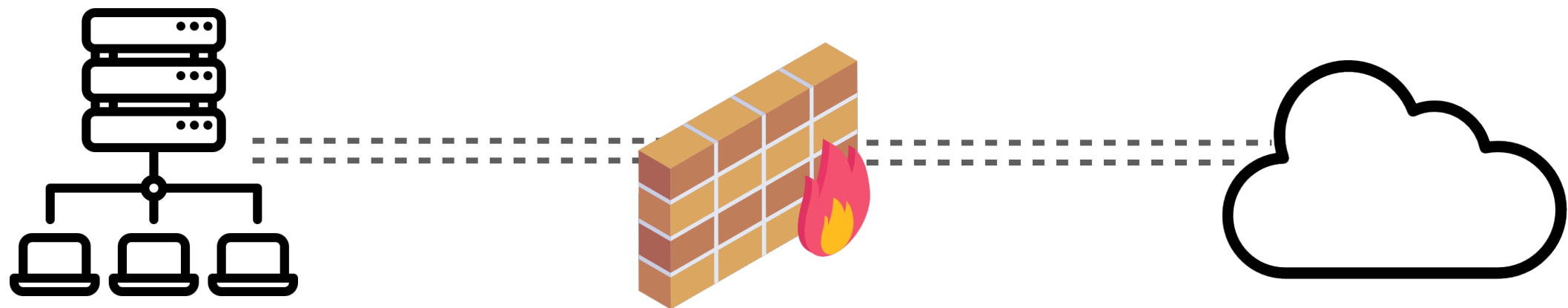
Network Security



Firewalls

An inter-network gateway that restricts data communication traffic to and from one of the connected networks in accordance with a security policy.

- This perimeter aims to protect the premises network from Internet-based attacks and to provide a single choke point where security and auditing can be imposed.



Internal (protected) network

Firewall

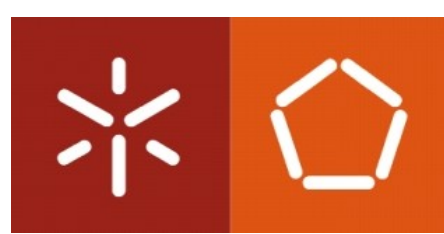
External (untrusted) network

- All traffic between inside and outside networks must pass through the firewall.
- Only authorised traffic is allowed to pass (following the security policy).
- Ideally, the firewall itself is immune to penetration.



Network Security

Firewalls



Types of Firewalls

» Packet-Filtering Firewall

It applies a set of rules to each incoming and outgoing IP packet and then forward or discard the packet.

- Filtering rules are based on information contained in a network packet:

- Source / Destination IP address
- Source / Destination transport-level address
- IP protocol field
- Interface

- Two default policies are used:

- Discard - which is not expressly permitted is prohibited
- Forward - which is not expressly prohibited is permitted

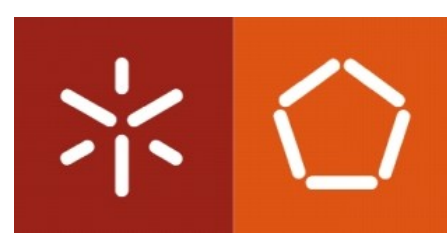
Packet-filtering examples

Rule	Direction	Src address	Dest addresss	Protocol	Dest port	Action
1	In	External	Internal	TCP	25	Permit
2	Out	Internal	External	TCP	>1023	Permit
3	Out	Internal	External	TCP	25	Permit
4	In	External	Internal	TCP	>1023	Permit
5	Either	Any	Any	Any	Any	Deny



Network Security

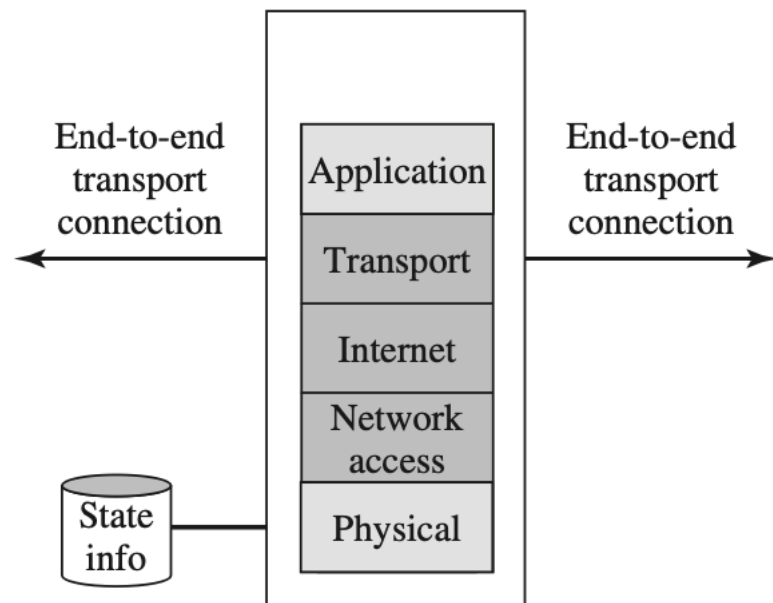
Firewalls



Types of Firewalls

» Stateful Inspection Firewall

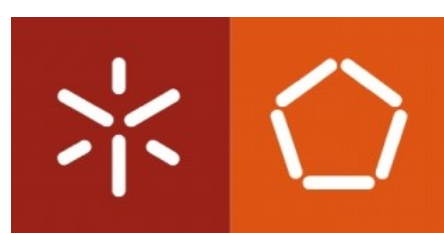
It creates a directory of established TCP connections and only allows incoming traffic to high-numbered ports (>1024) for packets fitting the profile of one of the entries in this directory.



Source Address	Source Port	Destination Address	Destination Port	Connection State
192.168.1.100	1030	210.9.88.29	80	Established
192.168.1.102	1031	216.32.42.123	80	Established
192.168.1.101	1033	173.66.32.122	25	Established
192.168.1.106	1035	177.231.32.12	79	Established
223.43.21.231	1990	192.168.1.6	80	Established
219.22.123.32	2112	192.168.1.6	80	Established
210.99.212.18	3321	192.168.1.6	80	Established
24.102.32.23	1025	192.168.1.6	80	Established
223.21.22.12	1046	192.168.1.6	80	Established

Network Security

Firewalls



Types of Firewalls

» Application-Level Gateway

It acts as an intermediary between external users and a requested server, controlling traffic and application session initiation to prevent attacks.

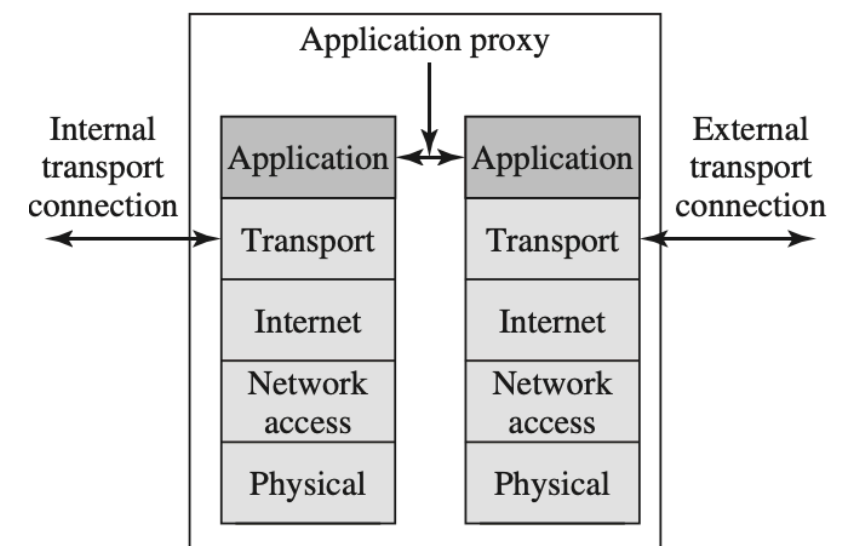
- The client relies on a proxy server to interact with the destination behind the firewall.

- Two connections are established:

- One between the client and the proxy server.
- One between the proxy server and its destination.

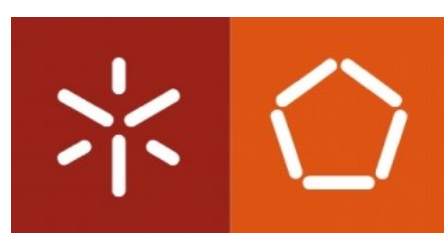
- They tend to be more secure than packet filters.

- A disadvantage is the additional processing overhead on each connection.



Network Security

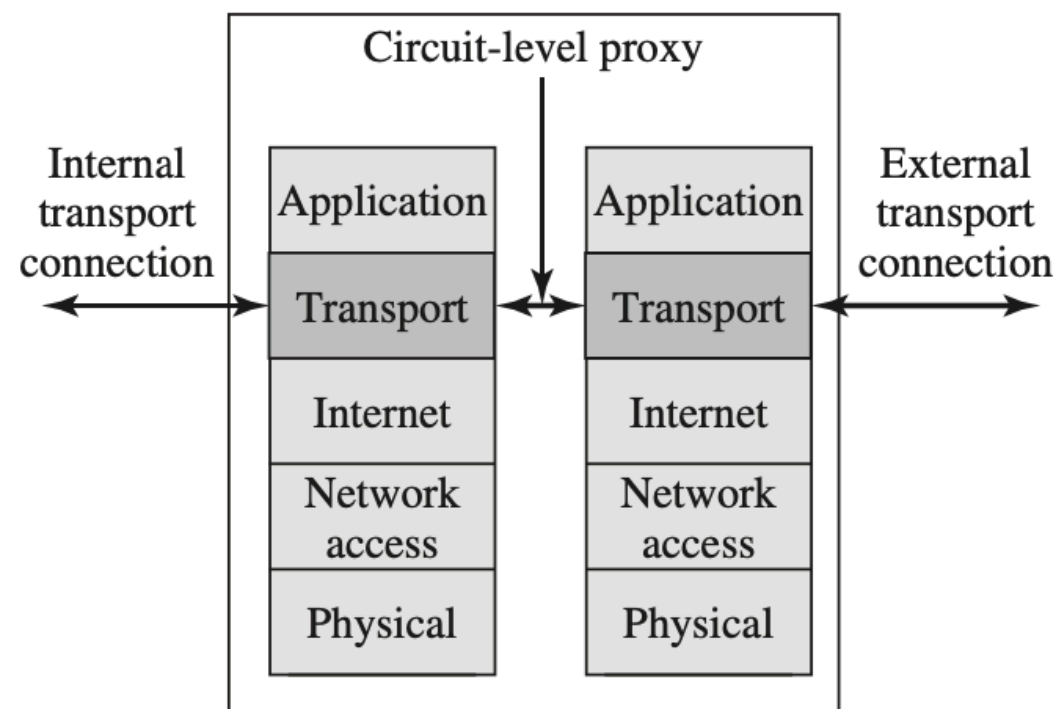
Firewalls



Types of Firewalls

» Circuit-Level Gateway

It does not permit an end-to-end TCP connection. Instead, the gateway establishes two TCP connections, one between itself and a TCP internal user and one between itself and an external TCP host.



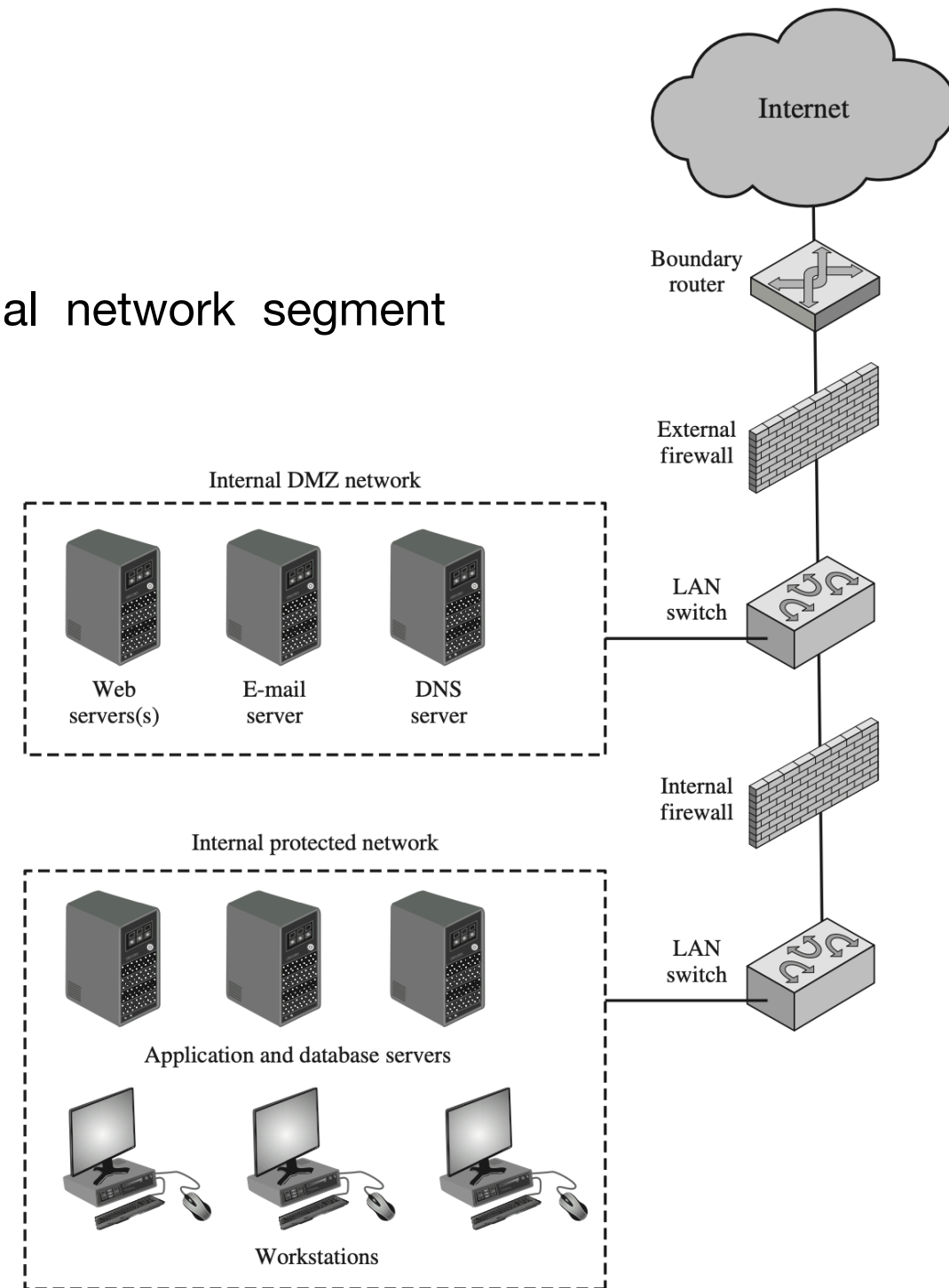
Network Security

Firewalls

DMZ Networks

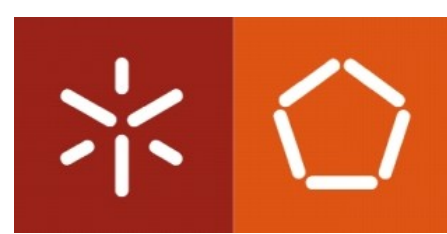
A firewall configuration that includes an additional network segment between an internal and an external firewall.

- DMZ - Demilitarised Zone.
- The internal firewall adds more stringent filtering capabilities.
- Multiple internal firewalls can be used to protect internal network segments from each other.



Network Security

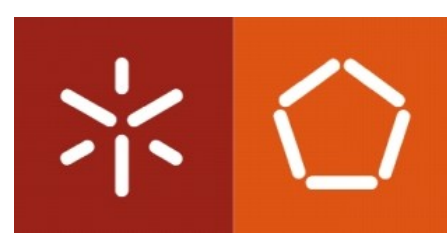
Firewalls



» Location & Topology

- **Host-resident firewall:** Includes personal firewall software and firewall software on physical and virtual servers.
- **Screening router:** A single router between internal and external networks with stateless or stateful packet filtering.
- **Single bastion inline:** A single firewall physical or virtual device between an internal and external router.
- **Single bastion T:** Similar to single bastion inline, but it has a third network interface on bastion to a DMZ where externally visible servers are placed.
- **Double bastion inline:** The DMZ is placed between bastion firewalls.
- **Double bastion T:** The DMZ is on a separate network interface on the bastion firewall.
- **Distributed firewall:** Multiple firewalls are placed within a private network.





Network Security

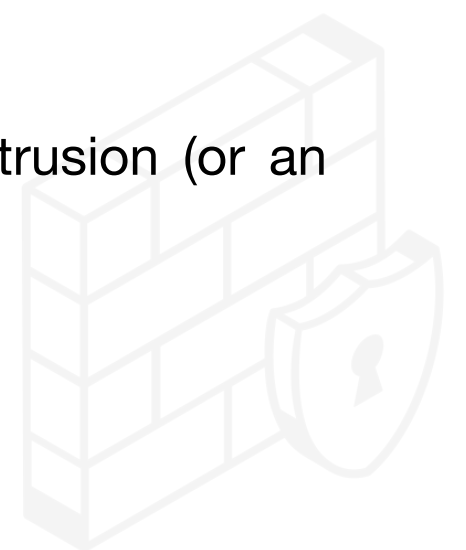
Intrusion Detection Systems (IDS)

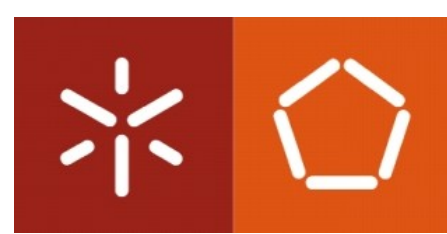
Security intrusion: Unauthorised act of bypassing the security mechanisms of a system.

Intrusion detection: A hardware or software function that collects and analyses information from different areas within a computer or network to identify possible security breaches.

An IDS comprises three components:

- **Sensors:** responsible for collecting data that might contain evidence of an intrusion attempt, e.g., network packets, log files, and system call traces.
- **Analysers:** based on sensed data, it is responsible for determining if an intrusion (or an attempt) has occurred.
- **User interface:** provides a user-friendly output view of the system's behaviour.

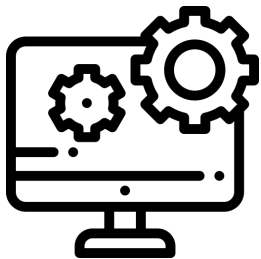




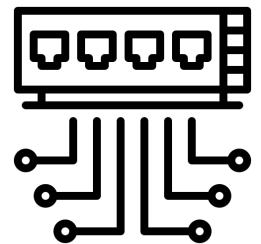
Network Security

Intrusion Detection Systems (IDS)

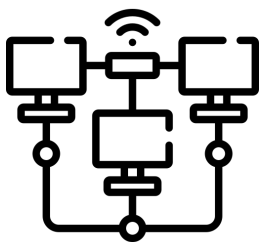
They are classified based on the source of sensed data:



Host-Based IDS (HIDS): Monitors a single host and its events, e.g., processes and system calls.

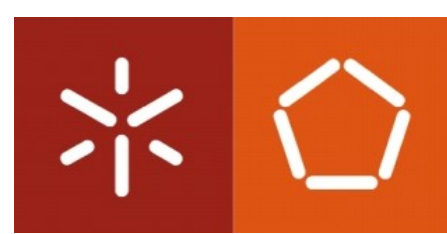


Network-Based IDS (NIDS): Monitors network traffic for particular network segments or devices and analyses network, transport, and application protocols seeking suspicious activity.



Distributed or Hybrid IDS: Combine information from sensors from the host and network.





Network Security

Intrusion Detection Systems (IDS)

Analysis approaches:

» Signature-based

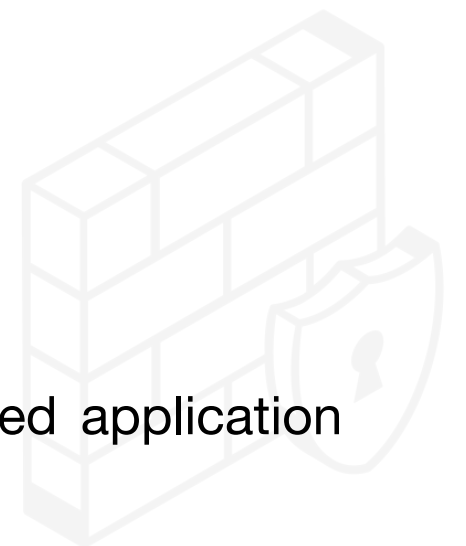


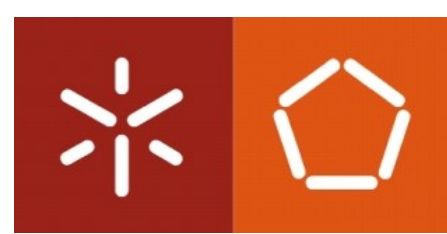
It uses a set of known data patterns (*signatures*) or attack rules (*heuristics*) that are compared with the observed behaviour to detect an intrusion attempt.

Example of a SNORT rule

```
alert udp $EXTERNAL_NET any -> $HOME_NET 177 ( msg:"X11 xdmcp info query"; flow:to_server;  
content:"|00 01 00 02 00 01 00|",fast_pattern,nocase; metadata:ruleset community;  
reference:nessus,10891; classtype:attempted-recon; sid:1867; rev:6; )
```

- A simple and effective approach to detect known attacks.
- Ineffective to detect unknown attacks and variants of known attacks.
- It is challenging to keep signatures up to date.
- Examples:
 - Application/Transport/Network layer reconnaissance and attacks, unexpected application services, and policy violations;





Network Security

Intrusion Detection Systems (IDS)

Analysis approaches:



» Anomaly-based



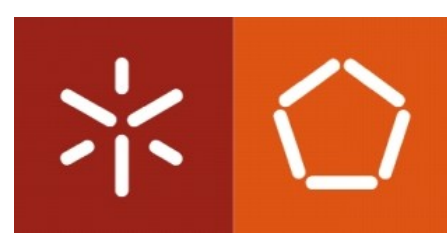
It involves monitoring the behaviour of legitimate users over some time. Then, further observed behaviours are compared with the baseline to identify an intrusion attempt.

- The anomaly is a deviation from a legitimate known behaviour.
- It assumes that something abnormal is probably suspicious.
 - Failed logging attempts, processor usage, network connections, etc.
- Comparatively effective in detecting new and unforeseen intrusion techniques.
- Defining normal and abnormal behaviour is challenging.
- Triggering alerts promptly can be difficult.
- The events' dynamics can affect the detection accuracy.
- Examples:
 - Denial-of-Service attacks, Scanning, and Worms.



Network Security

Intrusion Detection Systems (IDS)



Analysis approaches:

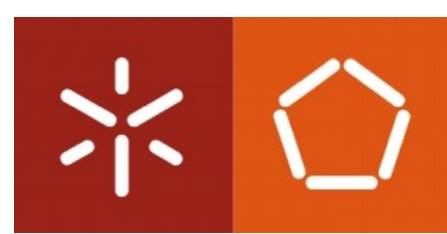


Stateful protocol analysis

Also called specification-based detection, it tracks protocol behaviour based on its standard, e.g., pairing requests with replies.

- The difference with the anomaly-based strategy is that there is no need for a baseline definition phase.
- It is comparatively simpler to trace protocol states and distinguish unexpected sequences.
- Tracing protocol state implies computational overhead.
- Unable to detect attacks with behaviour similar to protocol standard.
- It might be incompatible with proprietary protocols.
- Examples:
 - Network, Transport and Application protocols.





Network Security

Intrusion Detection Systems (IDS)

Detection approaches:

----- Statistics-based -----

- Uses predefined thresholds
 - Mean and standard deviation

----- Pattern-based -----

- Focused on known attacks through string matching
- Suitable for signature-based detection

----- Rule-based -----

- *If-then* or *if-then-else* rules are applied to construct a model of well-known intrusions.

----- State-based -----

- Exploit finite state machine derived from network behaviour.
- Suitable for anomaly-based and stateful protocol analysis.

----- Heuristic-based -----

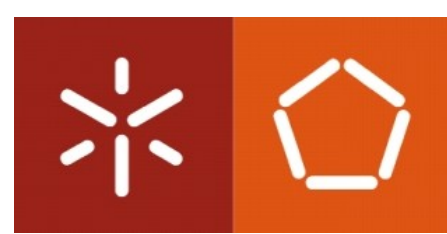
- Inspired by biological concepts
 - Immune system responses

----- Machine-learning-based -----

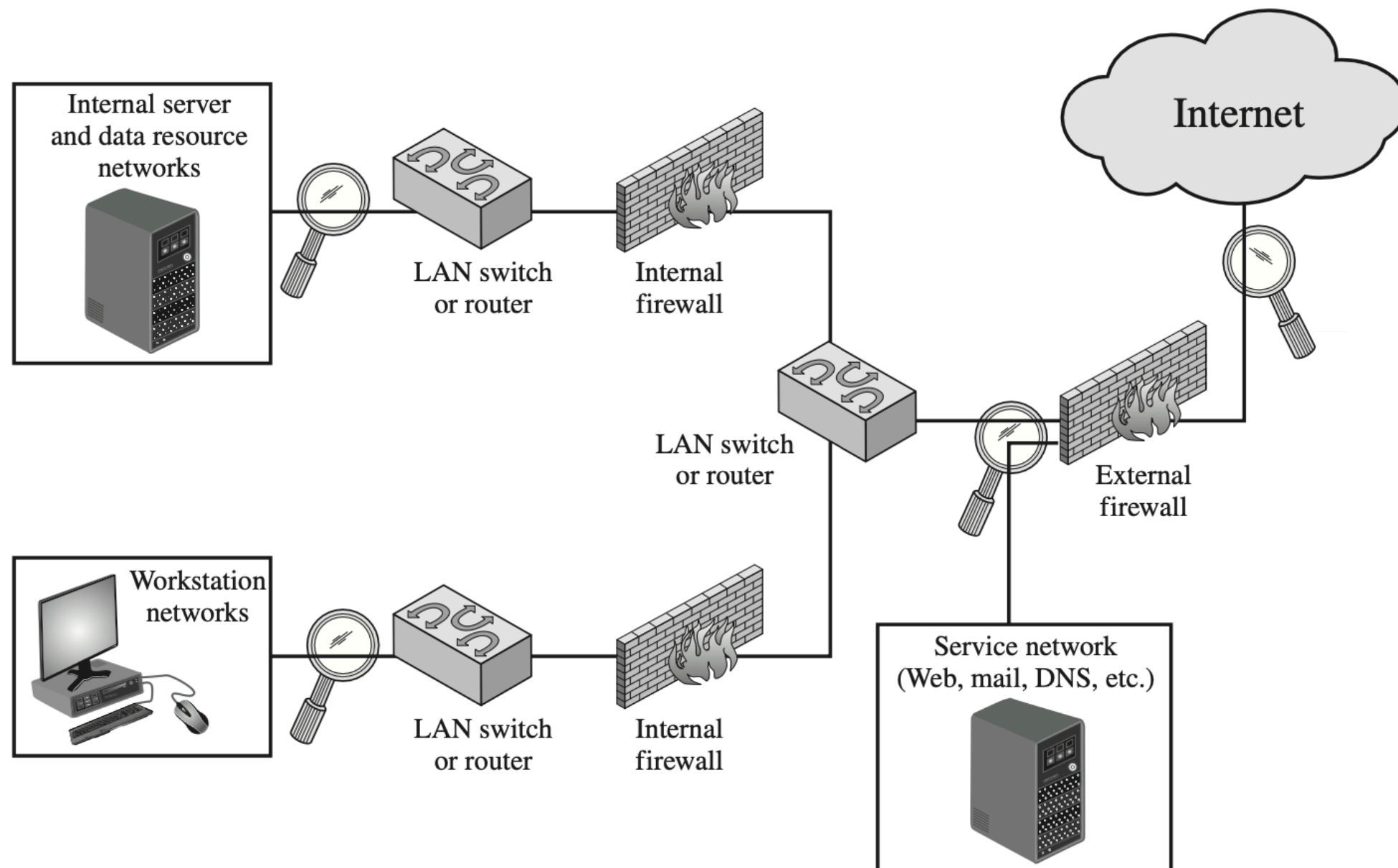
- Automatically determine a suitable classification model from a training data set.

Network Security

Intrusion Detection Systems (IDS)



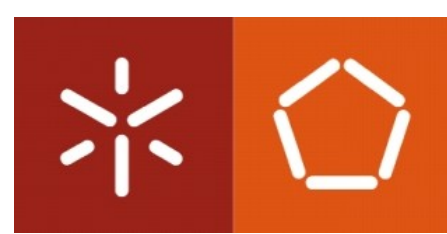
Example of NIDS Sensor deployment:



Source: Stallings, W. & Brown, L. Cryptography and Network Security: Principles and Practice

Network Security

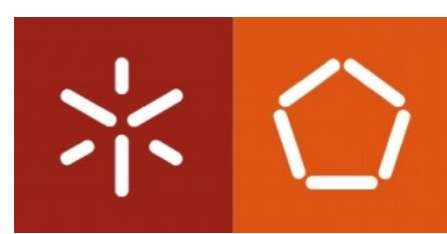
Intrusion Detection Systems (IDS)



Interoperability / Exchange formats

- **RFC 4766 - Intrusion Detection Message Exchange Requirements.**
- **RFC 4765 - The Intrusion Detection Message Exchange Format.**
- **RFC 4767 - The Intrusion Detection Exchange Protocol.**





Network Security

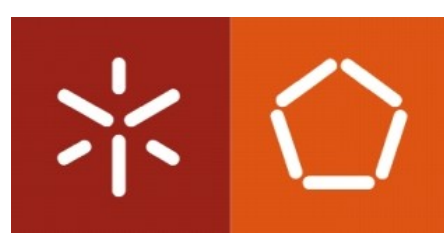
Intrusion Prevention Systems (IPS)

It is a system that can detect an intrusive activity and attempt to stop it, ideally before it reaches its targets.

NIST SP 800-82 Rev.2

- It includes all the capabilities of an intrusion detection system.
- Like an IDS, an IPS can be host-based, network-based, or distributed/hybrid.
- Once a malicious activity is detected, it can:
 - Block network packets across a perimeter or into a host.
 - Modify or block system calls by processes running on a host.
- Blocking packets can be done using a firewall.





Network Security

Intrusion Prevention Systems (IPS)

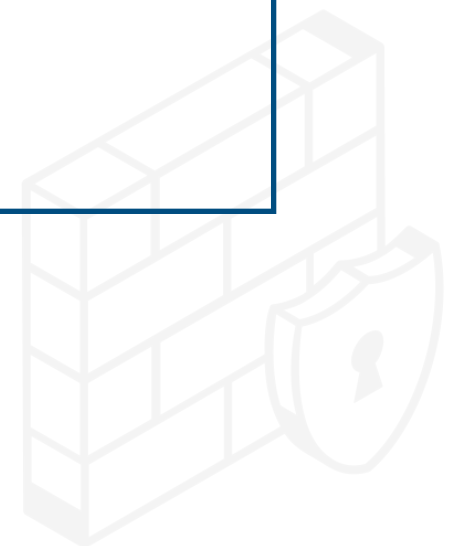
» Host-Based IPS

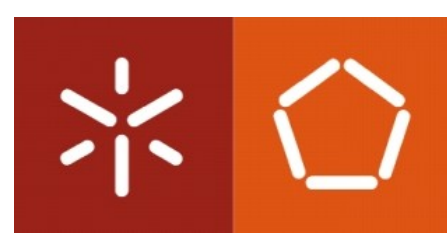
Examples of malicious behaviour addressed by HIPS:

- Modification of system resources
- Privilege-escalation exploits
- Buffer-overflow exploits
- Access to e-mail contact list
- Directory traversal

Areas for which HIPS typically offers protection:

- System calls
- File system access
- System registry settings
- Host input/output





Network Security

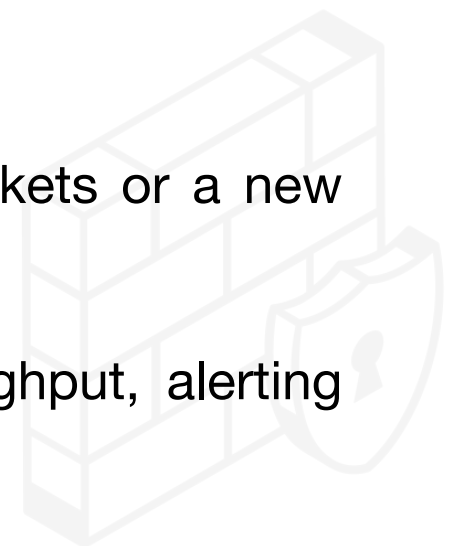
Intrusion Prevention Systems (IPS)

» Network-Based IPS

It is an inline NIDS with the authority to modify or discard packets and tear down TCP connections.

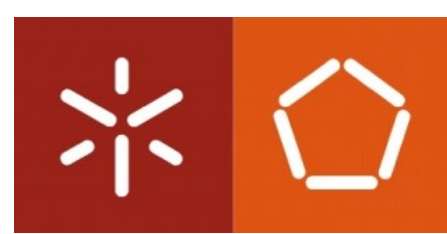
The general methods used to identify malicious packets include:

- **Pattern matching:** Scans incoming packets for specific byte sequences (*i.e.*, signature) stored in a database of known attacks.
- **Stateful matching:** Scans for attack signatures in the context of a traffic stream rather than individual packets.
- **Protocol anomaly:** Looks for deviation from protocols' standards.
- **Traffic anomaly:** Looks for unusual traffic activities, *e.g.*, a flood of UDP packets or a new service appearing on the network.
- **Statistical anomaly:** Relies on baselines of normal traffic activity and throughput, alerting when deviations are identified.



Network Security

Honeypots



Decoy systems designed to lure potential attackers away from critical systems.

They are primarily designed to:

- Divert an attacker from critical systems.
- Collect information about the attacker's activity.
- Encourage the attacker to stay on the system long enough for administrators to document the event and, ideally, respond.

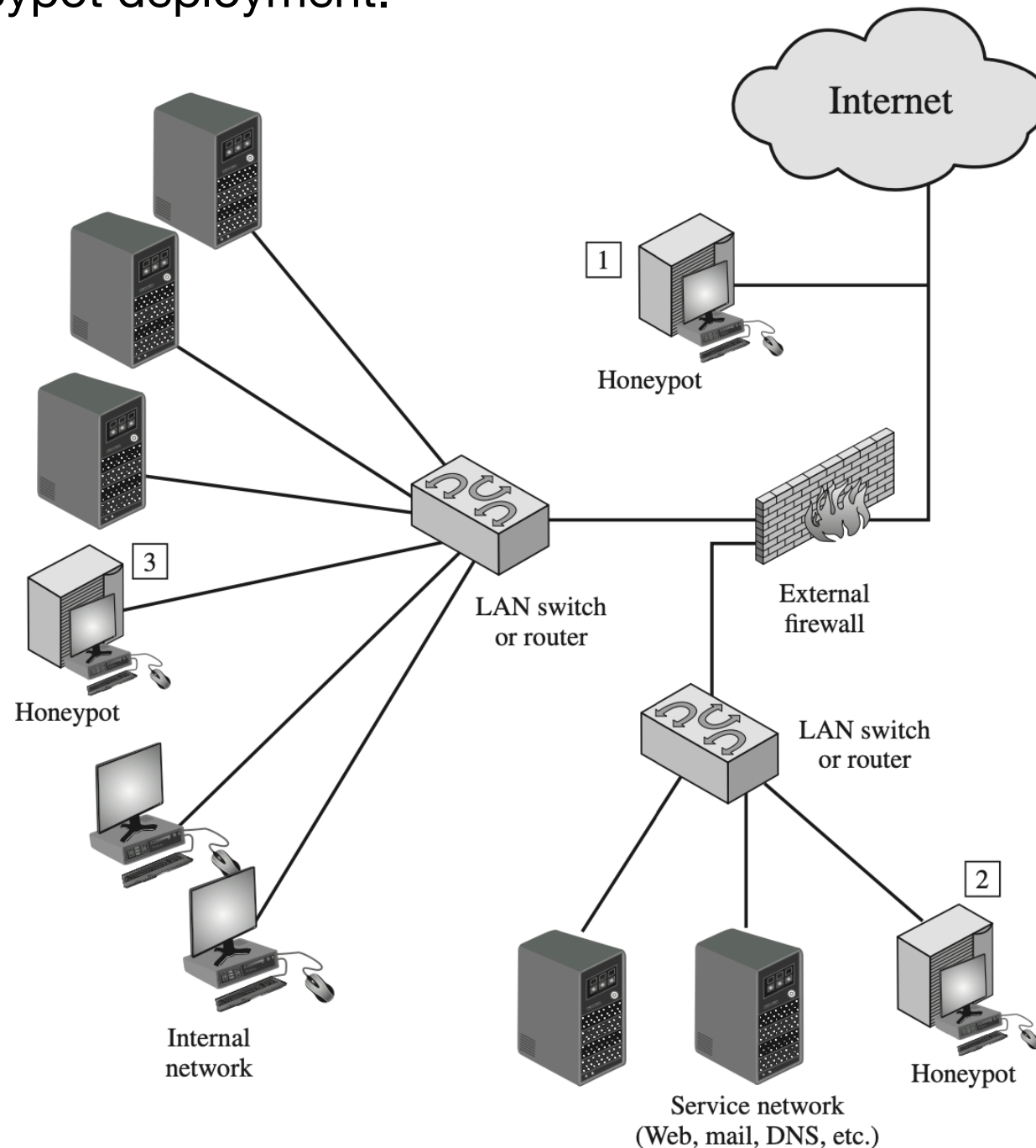
Honeypots are typically classified as:

- **Low interaction honeypot:** emulates a particular service or system well enough to provide a realistic initial interaction but does not execute a full version of those services or systems.
- **High interaction honeypot:** a real system with a full operating system, services and applications, which are instrumented and deployed where they can be accessed by attackers.

Network Security

Honeypots

Example of honeypot deployment.



Source: Stallings, W. & Brown, L. Computer Security: Principles and Practice



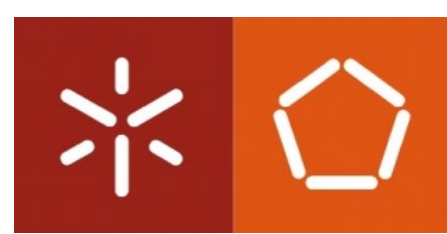
Network Security

Protocols & Standards



Network Security

Secure e-mail



» Secure/Multipurpose Internet Mail Extension (S/MIME)

An extension to the MIME protocol to support signing and/or encrypting e-mail messages.

It includes four new functions:

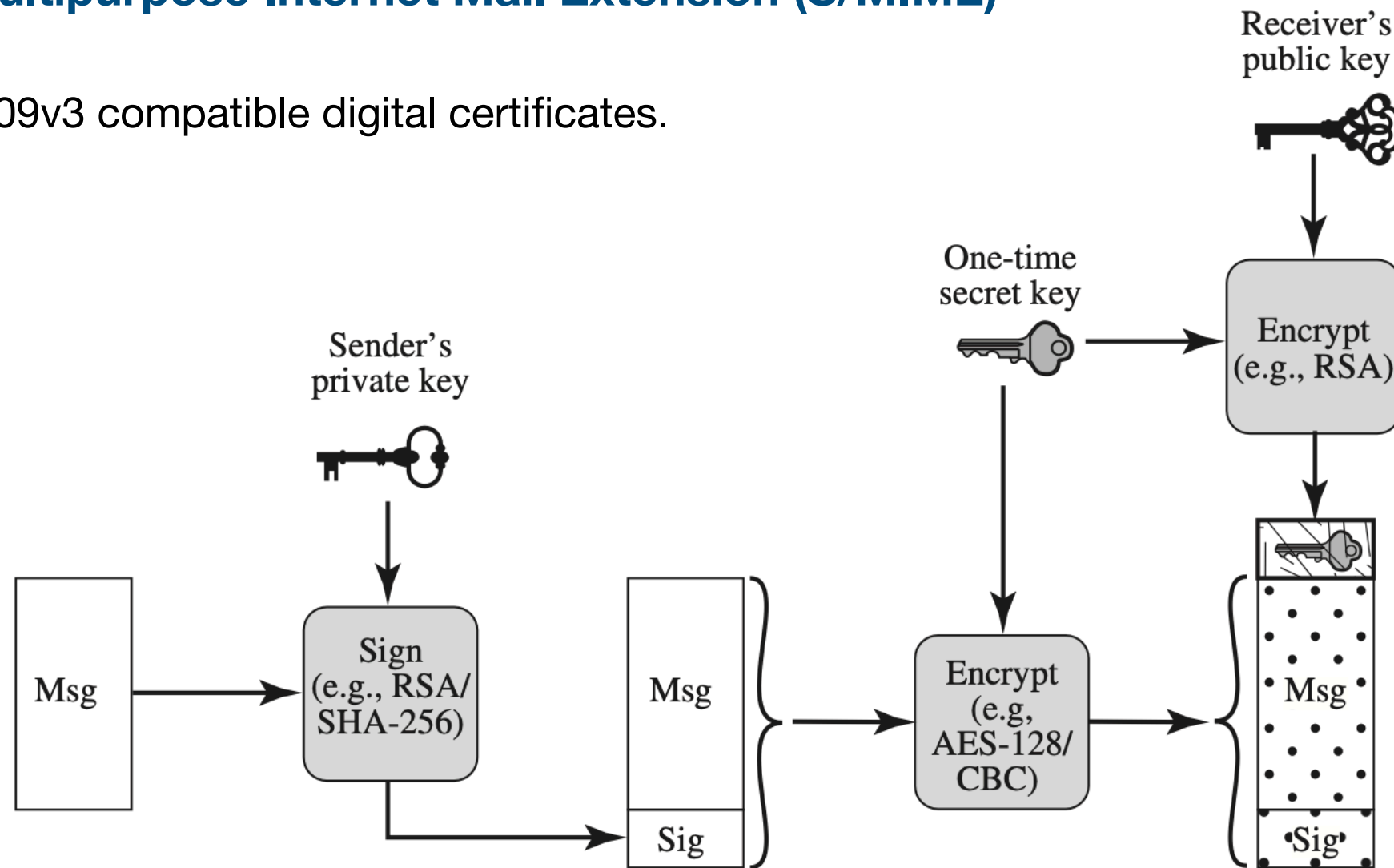
- **Enveloped data:** consists of encryption content of any type and the encryption keys of encrypted content for one or more recipients.
- **Signed data:** a digital signature formed by taking the message digest of the content to be signed, then encrypting that with the signer's private key. Only S/MIME-compatible recipients can view the message.
- **Clear-signed data:** a version in which only the message's signature is encoded. Thus, recipients not compatible with S/MIME can view the message, although they cannot verify the signature.
- **Signed and enveloped data:** signed-only and encrypted-only entities may be nested, so encrypted data may be signed, and signed or clear-signed data may be encrypted.

Network Security

Secure e-mail

➤ Secure/Multipurpose Internet Mail Extension (S/MIME)

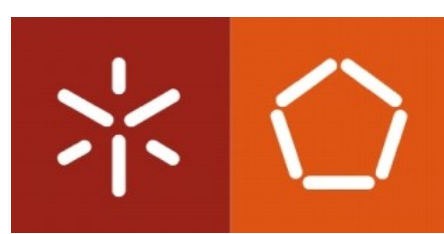
- It uses X.509v3 compatible digital certificates.



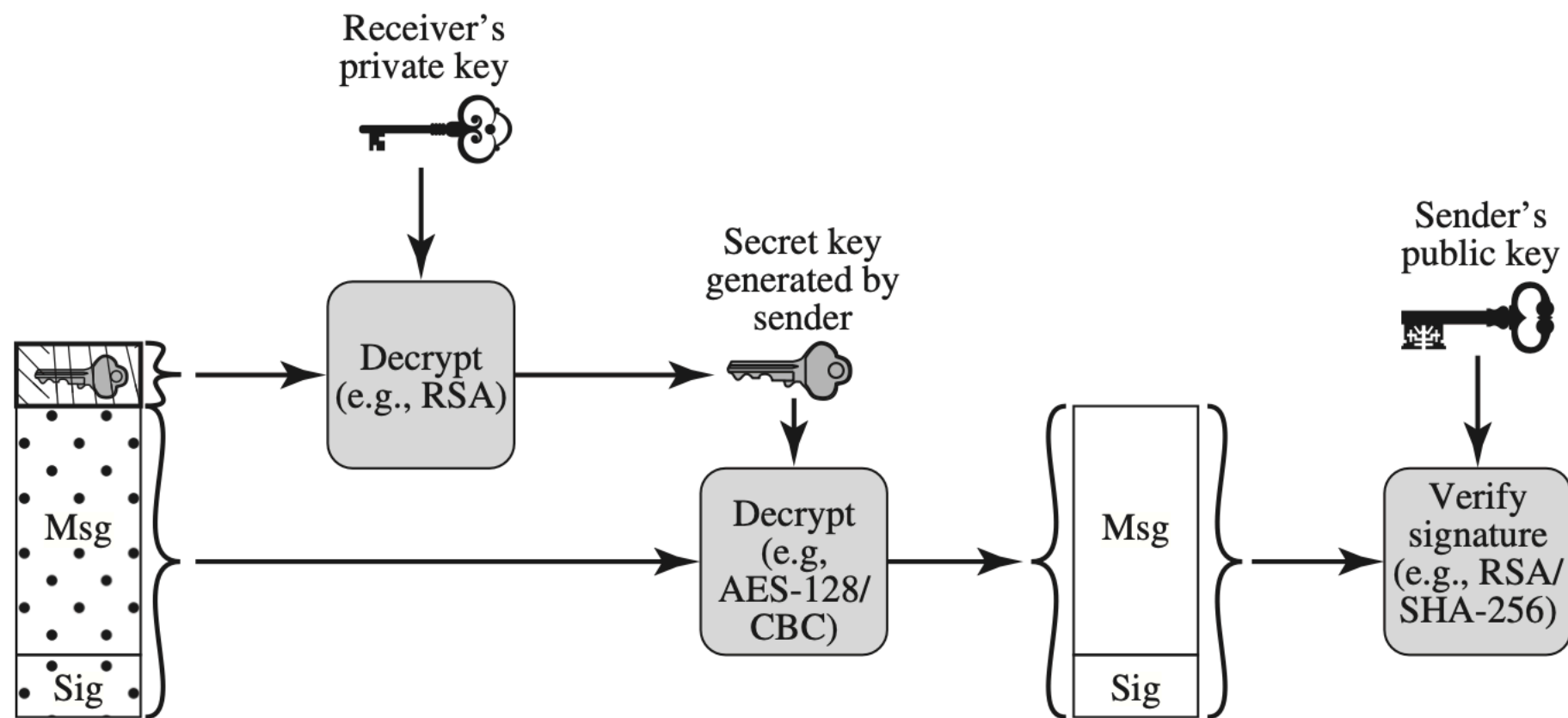
Message signature + Encryption

Network Security

Secure e-mail



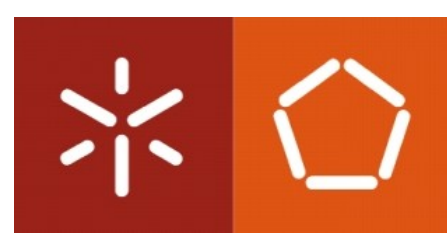
➤ Secure/Multipurpose Internet Mail Extension (S/MIME)



Message decryption + Signature verification

Network Security

Transport Layer



» SSL/TLS

Secure Sockets Layer (SSL)

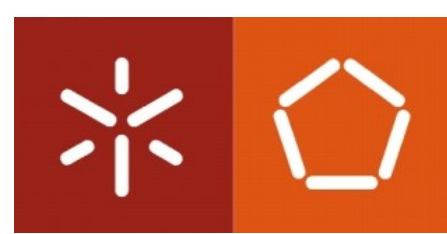
Transport Layer Security (TLS)

- Currently in version 3, i.e., TLSv1.3 - RFC 2246
- Provides Security services to TCP, including:
 - Confidentiality through symmetric encryption
 - Authenticity based on public-key cryptography
 - Integrity based on Message Authentication Code
- It supports:
 - Server authentication - typically using X.509 certificates
 - Two-way authentication - the client is also authenticated

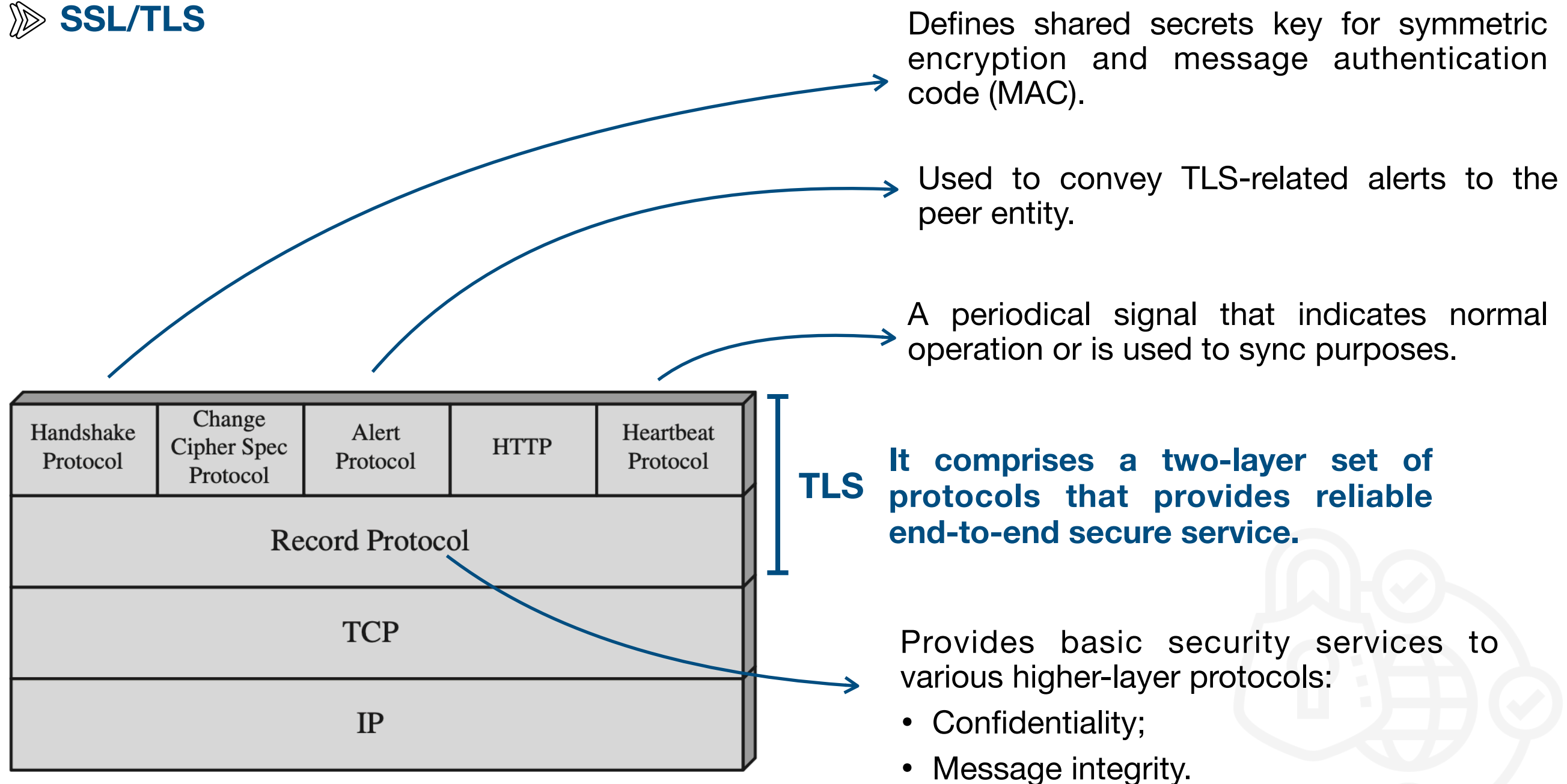


Network Security

Transport Layer

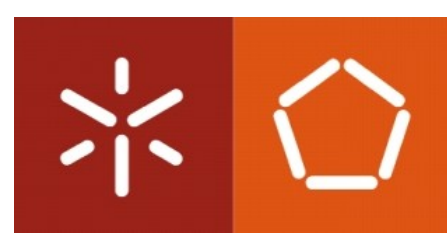


» SSL/TLS

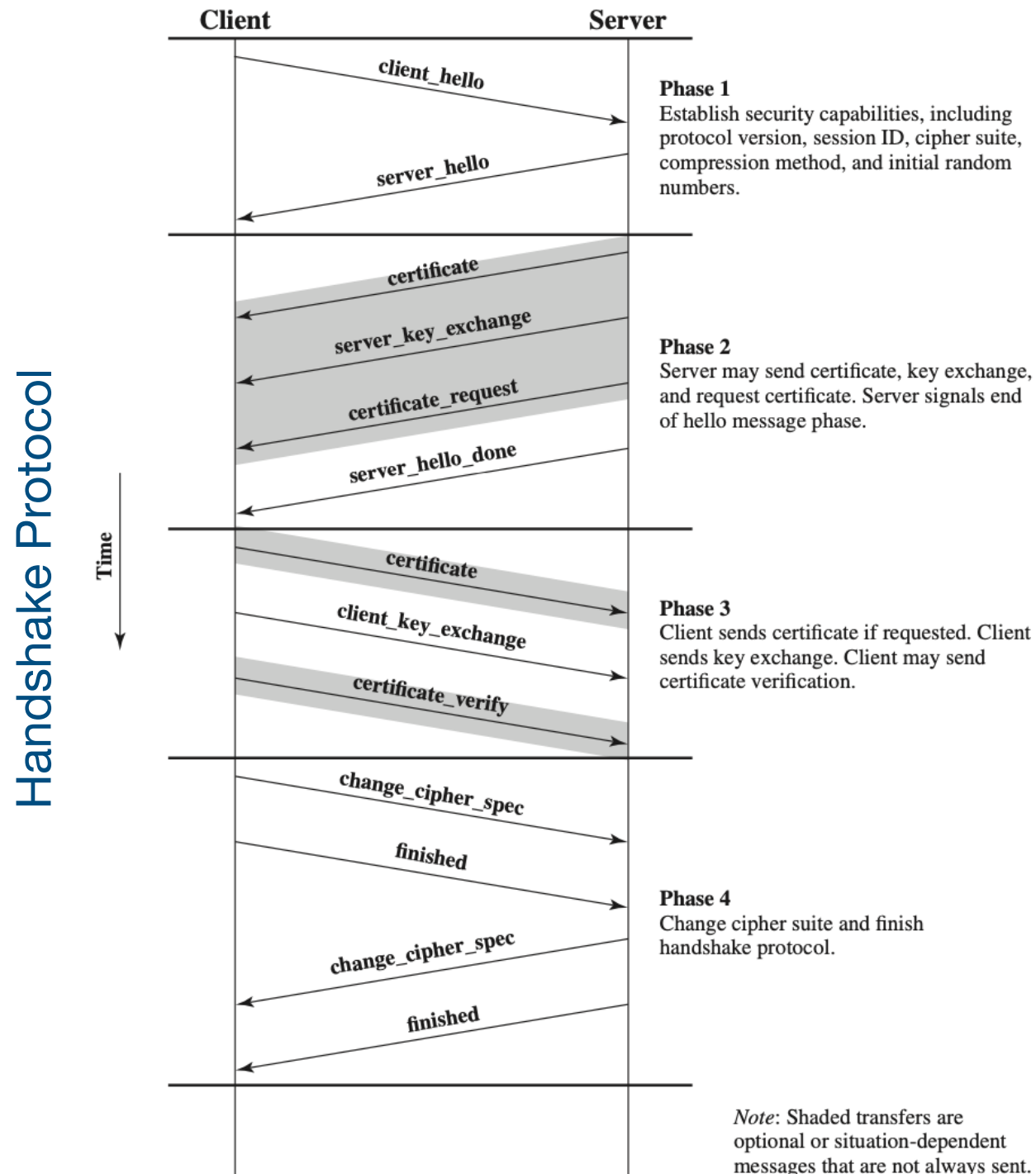


Network Security

Transport Layer



SSL/TLS



The **CipherSuite** is a list containing the combinations of cryptographic algorithms supported by the client in decreasing order of preference.



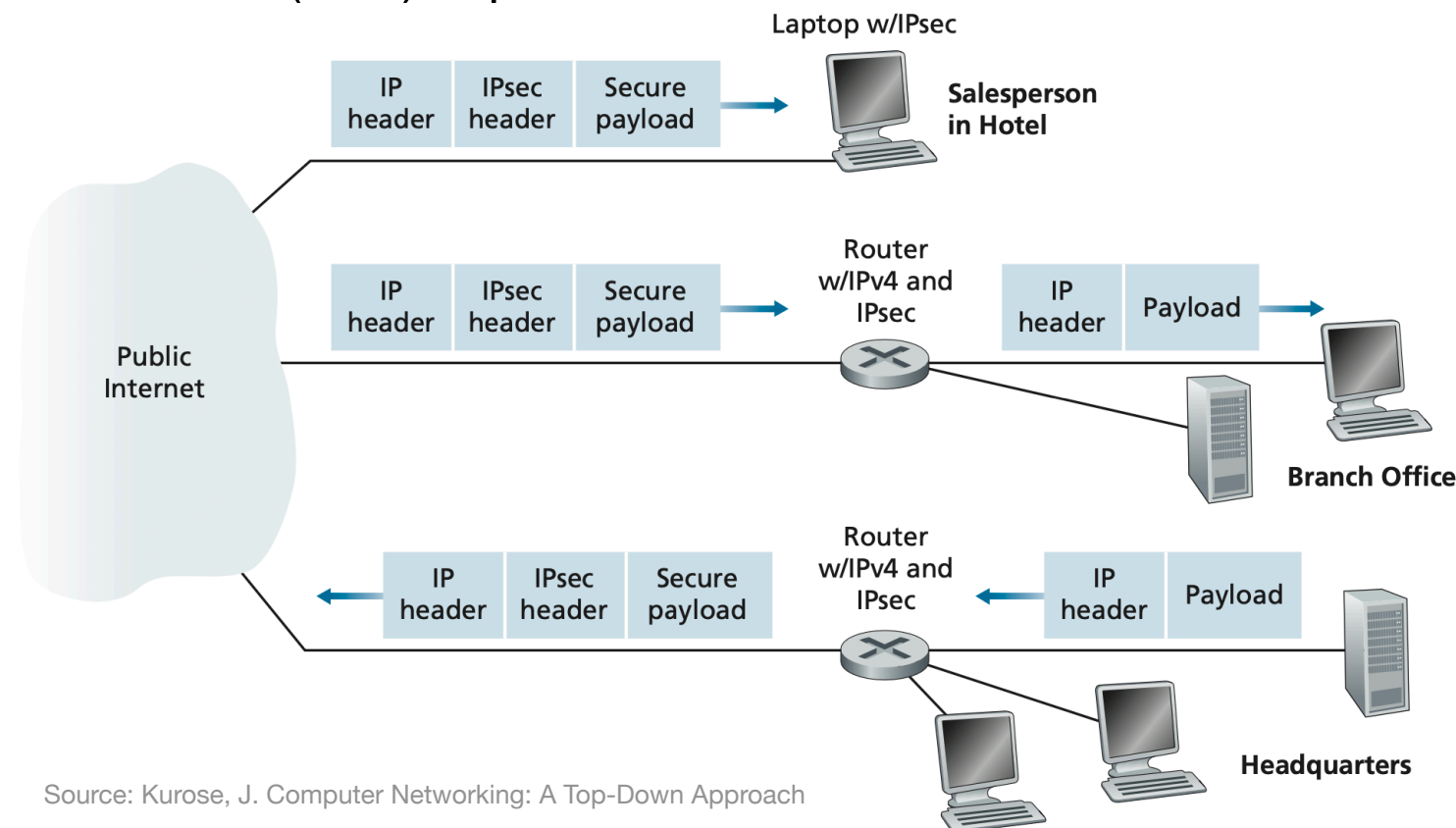
Network Security

Network Layer

» Internet Protocol Security (IPsec)

IPsec secures IP datagrams between any two network-layer entities, including hosts and routers.

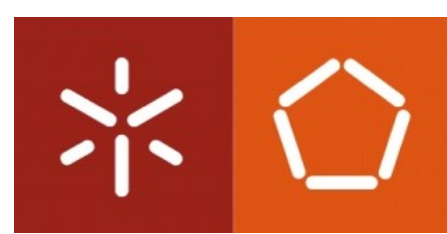
- It is compatible with IPv4 and IPv6
- Provides authentication, confidentiality and key management.
- The encrypted payload can be a TCP segment, a UDP segment, an ICMP message, etc.
 - It allows securing applications with no security mechanisms.
- Used in Virtual Private Network (VPN) implementations.



Source: Kurose, J. Computer Networking: A Top-Down Approach

Network Security

Network Layer



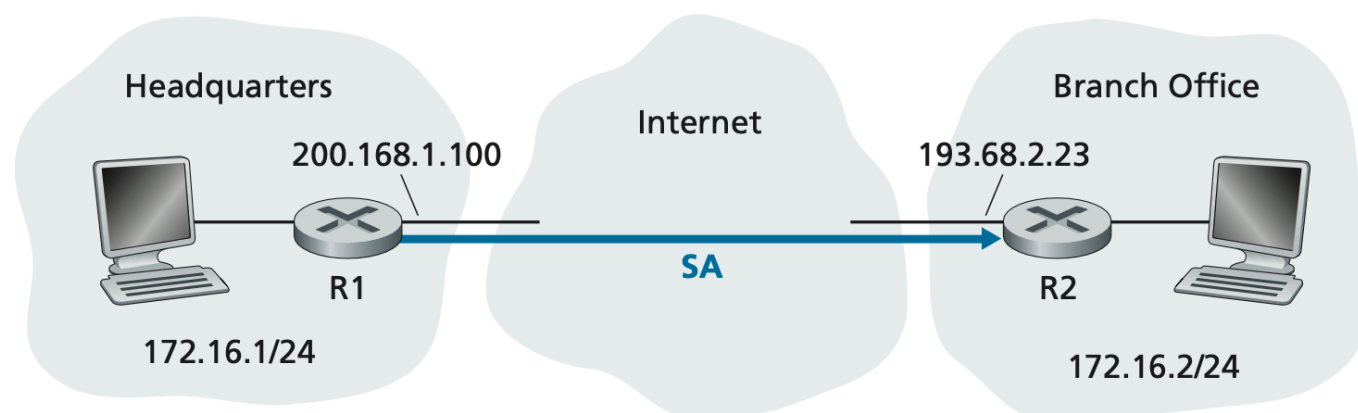
» Internet Protocol Security (IPsec)

In the IPsec protocol suite, there are two principal protocols:

- **Authentication Header (AH)**: provides source authentications and data integrity but does not provide confidentiality.
- **Encapsulation Security Payload (ESP)**: provides source authentication, data integrity, and confidentiality.
 - Crucial for VPN deployments.

ESP

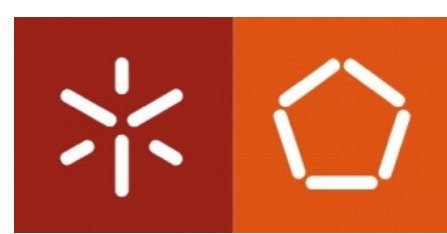
- Before exchanging IPsec datagrams, source and destination entities create a network-layer logical connection, *i.e.*, **Security Association (SA)**.
- SA is unidirectional from source to destination.



Source: Kurose, J. Computer Networking: A Top-Down Approach

R1 SA's state information:

- Security Parameter Index (SPI)
- SA's origin and destination interfaces
- Type of encryption, e.g., AES-CBC
- Encryption key (uses **Internet Key Exchange (IKE)** protocol)
- Integrity check, e.g., HMAC
- Authentication key



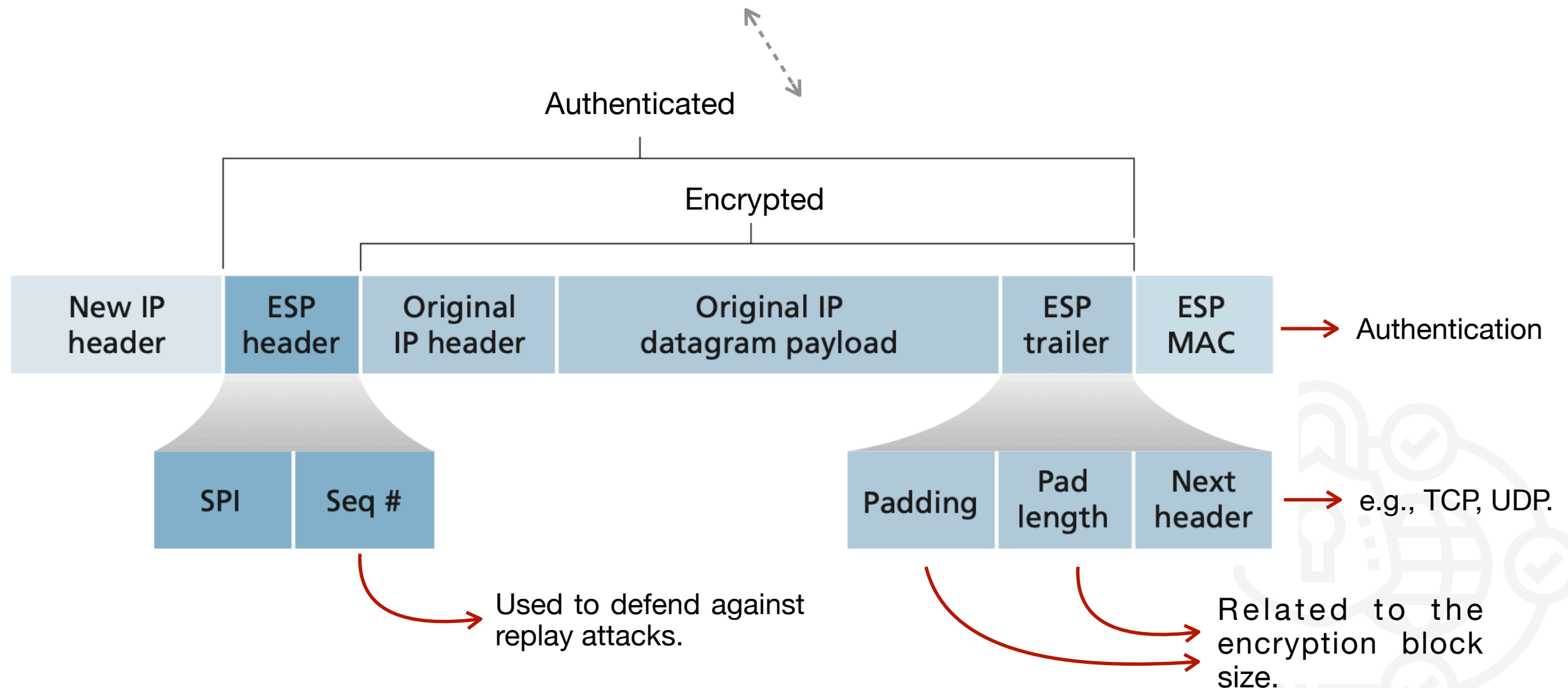
Network Security

Network Layer

» Internet Protocol Security (IPsec)

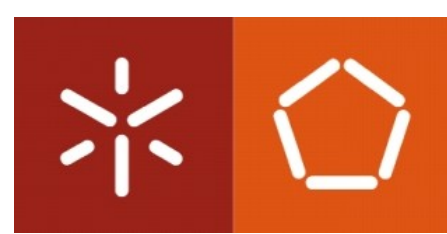
Datagram

- It has two different packet forms, i.e., Tunnel mode and Transport mode:



Source: Kurose, J. Computer Networking: A Top-Down Approach

Network Security



» Exercise

1- A bug discovered in 2014 in the TLS software created one of the potentially most catastrophic TLS vulnerabilities. The bug was in the open-source OpenSSL implementation of the Heartbeat Protocol and was identified with CVE-2014-0160.

Analyse the vulnerability description to identify whether a design flaw in the TLS Heartbeat Protocol specification caused it.

2 - Describe how the HTTPS protocol works and its relationship with TLS protocol.





University of Minho
School of Engineering



Cryptography & Network Security

Bachelor in Telecommunications and Informatics Engineering

João Marco Silva

Department of Informatics
joaomarco@di.uminho.pt

2024/2025